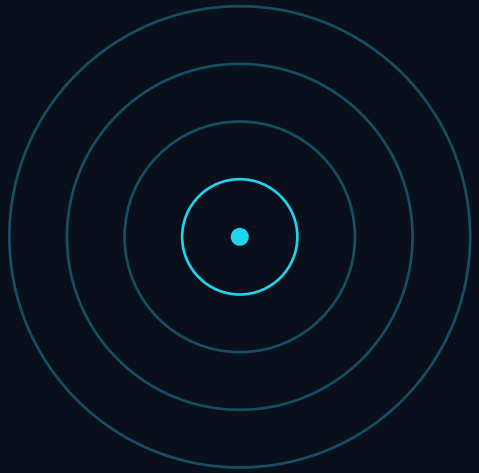
AI PORTFOLIO

AI Governance Readiness Agents



A 7-agent assessment that turns enterprise evidence into a governed AI inventory: Shadow AI discovery, risk conditions, NIST AI RMF control mapping, human decision gates, and a readiness roadmap.

Live Demo | Claude API | OpenAI API

github.com/danvzla/AI-Governance-Readiness-Agents

Daniel Mazzini · Principal Architect & Senior TPM

THE PROBLEM

Shadow AI, unclear ownership, and policy without evidence

!

AI is in use, but unseen

Teams adopt AI tools, SDKs, API keys, and IDE agents faster than anyone can inventory them, often through personal accounts.

?

No one owns the risk

Without a register and named owners, leaders can't tell which AI touches source code, customer data, or regulated processes.

→

Policy starts from opinion

Rules get written before anyone knows what is actually in use, so controls miss the real exposure and the gaps stay invisible.

THE APPROACH

Govern what you can see: start with evidence

Policy first

Write the rules before knowing what exists. Hard to enforce and quickly outdated.

Blind

Block everything

Ban AI tools outright. Usage moves to personal accounts and becomes harder to see.

Pushes it underground

Evidence-first governance

Discover what exists, label every finding as fact, assumption, or unknown, and let people decide the critical calls.

This project

ARCHITECTURE

A 7-agent pipeline: evidence in, governed roadmap out



▲ Evidence labels on every conclusion: FACT · ASSUMPTION · UNKNOWN (with an owner)

AGENTS 01 – 02

Read the evidence, then find the Shadow AI

01

Evidence Intake

Reads the scope, the customer's pre-work, and evidence coverage, and flags what is missing before any analysis starts.

IN: pre-work + evidence sources → OUT: scope, coverage, evidence gaps

02

Shadow AI Discovery

Finds AI tools, SDKs, API keys, agent configurations, AI traffic, and unsanctioned accounts across Git, proxy, CASB, endpoint, and identity data.

IN: in-scope evidence → OUT: discovered AI assets, each with its source

Rules where rules work: intake is deterministic; discovery combines detection rules with model reasoning.

AGENTS 03 – 04

Build the register, then turn gaps into conditions

03

Inventory & Ownership

Builds the AI estate register and compares what was discovered with what the customer declared, including named business and technical owners.

IN: discovered + declared AI → OUT: register, owners, declared-vs-found gaps

04

Risk & Conditions

Turns each gap into a governance condition with a severity, an owner, a required condition, a proposed disposition, and the next gate.

IN: register + evidence → OUT: risk, owner, condition, disposition, gate

Discovered vs declared: the sample register surfaces AI the customer never listed in its own pre-work.

AGENTS 05 + 07

Map controls, then score readiness

05

Control Mapping

Maps every condition to a control and a control type, aligned with the NIST AI RMF functions: Govern, Map, Measure, and Manage.

IN: risk conditions → OUT: control, NIST AI RMF function, control type

07

Roadmap & Scorecard

Scores seven governance domains from 0 to 4 and builds a 30/60/90/180-day roadmap with an executive recommendation and a PDF summary.

IN: reviewed conditions → OUT: readiness scorecard, roadmap, executive summary

Agent 06, the human governance review, sits between these two steps: no roadmap is built on unreviewed critical findings.

AGENT 06 · KEY DESIGN DECISION

Agents propose, humans decide: every critical finding gets a human disposition

The governance gate

For critical and high-risk findings:

- agent recommendation + evidence
- named owner
- required condition
- human disposition
- roadmap impact

Four dispositions

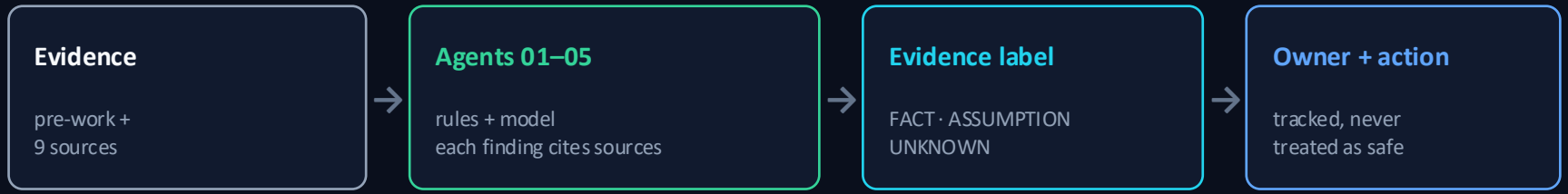
- Remediate: fix before the next gate
- Assure: keep it, with added assurance evidence
- Block / Pause: stop until the condition is met
- Accept: the owner accepts the documented risk

Unknowns stay visible: an UNKNOWN is never treated as safe. It gets an owner and a follow-up action.

THE EVIDENCE MODEL

Every conclusion carries its evidence label

Agents work only from in-scope evidence: the customer's pre-work plus up to nine sources such as identity exports, Git scans, proxy and DNS logs, CASB reports, cloud billing, and vendor registers. Each conclusion is tagged FACT, ASSUMPTION, or UNKNOWN.



Deliberate scope: synthetic evidence for a fictional operator. In Claude or OpenAI mode, only in-scope sources are sent, and model responses are validated before they are shown.

SAMPLE OUTPUT

Findings with owners, scores with reasons

Agent 04 — Risk & conditions

R1 · CRITICAL · REMEDIATE

"API key committed to a repository: revoke and rotate, with secret scanning in CI, before the next release"

R2 · CRITICAL · BLOCK

"AI tooling wired to the production replica through MCP: human approval, kill switch, and tool boundary first"

Agent 07 — Readiness scorecard (0–4)

Security → 3 of 4

"Identity, endpoint, and network monitoring surfaced these findings; AI-specific controls lag"

Risk and impact → 0 of 4

"No AI-specific tiering or impact method"

WHAT THIS DEMONSTRATES

The assessment at a glance

7

Chained agents

intake · discover · inventory · risk · controls · review · roadmap

10

Evidence sources

pre-work + 9 evidence types

11

Risk conditions

each with owner, condition, and gate

3

Evidence labels

FACT · ASSUMPTION · UNKNOWN

4

Human dispositions

remediate · assure · block · accept

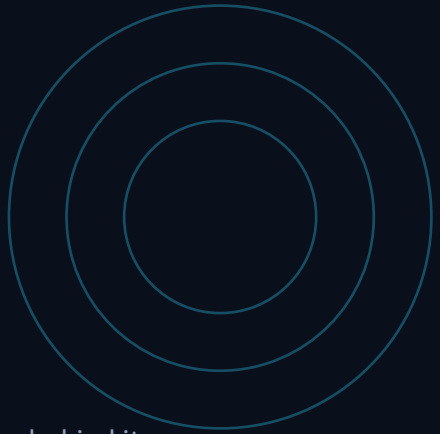
7

Readiness domains

scored 0–4, mapped to NIST AI RMF

TRY IT

Try it in demo mode, no API key needed



Evidence first

Every conclusion is tagged FACT, ASSUMPTION, or UNKNOWN and traced to the evidence source behind it.

Humans decide

Critical and high-risk findings need a human disposition before they reach the roadmap.

Grounded in real governance work

Built on the AI Governance Readiness service method and mapped to the NIST AI RMF.

Live demo · Demo, Claude, or OpenAI mode

github.com/danvzla/AI-Governance-Readiness-Agents